第 21 章 网络端点安全

0. 学习目标总览

教材给出本章八个学习目标：

1. 解释作为计算机与网络安全策略一部分的防火墙的作用。
2. 列出防火墙的关键特征。
3. 了解防火墙位置和配置的各种选择的优点。
4. 了解入侵检测的基本原理和要求。
5. 讨论入侵检测系统的主要特征。
6. 描述一些主要的恶意软件。
7. 概述恶意软件防御的关键要素。
8. 讨论分布式拒绝服务攻击的本质。

本章从网络角度讨论服务器、工作站和移动设备等端点的安全。整体思路是：防火墙建立受控边界，IDS 发现已经发生或正在发生的可疑活动，恶意软件防御覆盖攻击前后，DDoS 防御则围绕资源耗尽攻击进行预防、检测、过滤和追踪。

1. 学习目标 1：防火墙在安全策略中的作用

1.1 基本定位

防火墙通常部署在本地网络与因特网之间，形成一条受控链路和外部安全边界；也可部署在企业网络内部，用来隔离不同网段。它是主机安全服务的重要补充，并体现“深度防御”：即使某一层防护失效，其他层仍可限制攻击扩散。

防火墙的三个基本设计目标是：

1. 内外之间的全部流量都必须经过防火墙，不能存在绕行路径。
2. 只有本地安全策略授权的流量才允许通过。
3. 防火墙本身必须能够抵抗渗透，应运行在安全、可信的系统上。

1.2 主要作用

作用	说明
集中阻断	形成统一阻止点，拦截未授权访问、脆弱服务、IP 欺骗和路由攻击。
监控与审计	为安全事件记录、审计和告警提供集中位置。
附加网络功能	可承载网络地址转换和网络使用记录等功能。
VPN 平台	可作为虚拟专用网的实现平台。

1.3 能力边界

防火墙并不是完整的端点安全方案，主要局限包括：

- 不能防御绕过防火墙的通信路径；
- 不能完全防御内部人员造成的威胁；
- 不能阻止绕开内部隔离边界的无线通信；
- 不能避免移动设备在外部感染后接入内部网络并传播恶意软件。

因此，防火墙必须与主机防护、入侵检测、恶意软件防御及事件响应配合使用。

2. 学习目标 2：防火墙的关键特征

2.1 四种访问控制功能

功能	控制内容
服务控制	决定允许哪些入站或出站因特网服务，可依据地址、协议、端口或代理解释结果进行过滤。
方向控制	决定某类服务请求允许从哪个方向发起。
用户控制	根据用户身份决定能否访问服务；外部用户控制需要安全认证技术。
行为控制	限定服务的使用方式，例如过滤垃圾邮件或限制外部只能访问 Web 服务器的部分信息。

2.2 四类防火墙

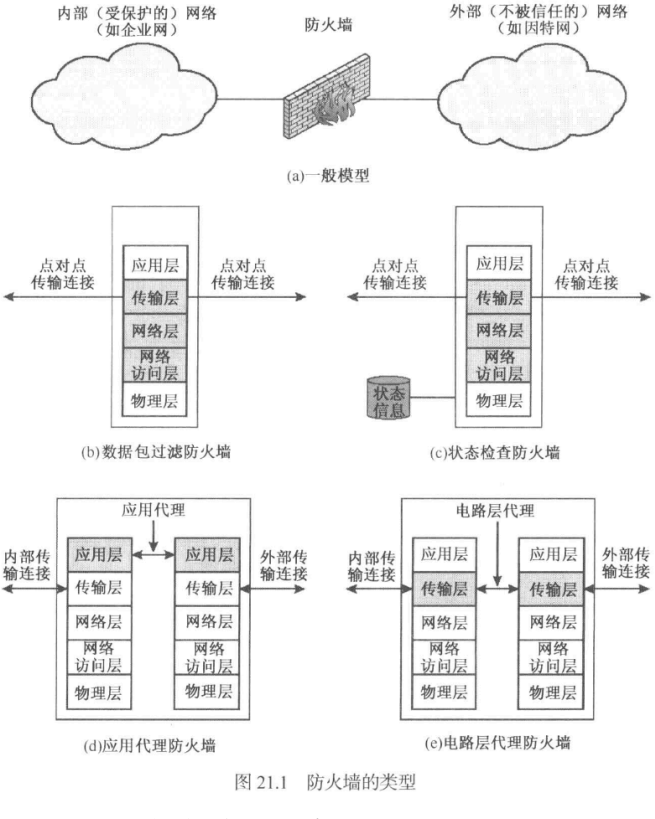


图 21.1　防火墙的类型

图 21.1 四类防火墙检查层次与连接方式

类型	工作方式	优点	局限
数据包过滤防火墙	独立检查每个 IP 数据包，根据源/目的 IP、端口、IP 协议和接口等字段决定转发或丢弃。	简单、快速、对用户透明。	不检查上层数据，日志和用户认证能力有限，易受协议欺骗及错误配置影响。
状态检查防火墙	在包过滤基础上维护当前连接目录，只允许与合法连接状态相符的流量通过。	能限制伪装成响应的入站流量，还可跟踪 TCP 序号或部分应用数据。	仍需正确维护状态和策略。

类型	工作方式	优点	局限
应用层网关	作为应用代理终止原连接，再代表用户与远程应用建立连接，并检查、转发应用数据。	可限制应用的具体功能，日志和审计能力强。	每个连接都需额外处理，且每种受支持应用都要有相应代理。
电路层网关	建立内外两个 TCP 连接，在连接获准后中继 TCP 段，通常不检查内容。	适合信任内部用户的场景，出站处理开销较低。	对应用内容的控制弱于应用层网关。

2.3 包过滤规则与默认策略

数据包过滤器可以是正过滤器，只放行满足条件的数据包；也可以是负过滤器，拒绝满足条件的数据包。规则按顺序匹配，因此规则顺序本身就是安全策略的一部分。

默认策略	含义	权衡
默认丢弃	未被明确允许的流量全部丢弃。	更保守、更安全，但必须逐项开放所需服务。
默认转发	未被明确禁止的流量全部转发。	使用方便，但管理员必须持续发现并封堵新威胁。

应用协议可能使用动态端口。例如 FTP 具有控制连接和数据连接，单纯按端口放行容易产生过宽规则。状态检查或应用层网关能利用连接上下文，更准确地处理此类协议。

2.4 典型包过滤攻击及对策

攻击	原理	对策
IP 地址欺骗	外部攻击者伪造内部主机源地址，利用基于源地址的信任。	在外部接口丢弃源地址属于内部网络的数据包。
源路由攻击	攻击者在数据包中指定路由，试图绕过正常安全路径。	丢弃所有使用源路由选项的数据包。
极小数据段攻击	将 TCP 头部拆到后续分段，规避只检查首段的过滤器。	要求首段至少包含预定的最小 TCP 头部，并关联丢弃其余分段。

> **源路由**
>
> 其是一种允许数据包发送方**指定该数据包在网络中传输路径**的技术。
>
> 详见： 什么是源路由 (电子版)

3. 学习目标 3：防火墙的位置与配置

3.1 外部防火墙、DMZ 与内部防火墙

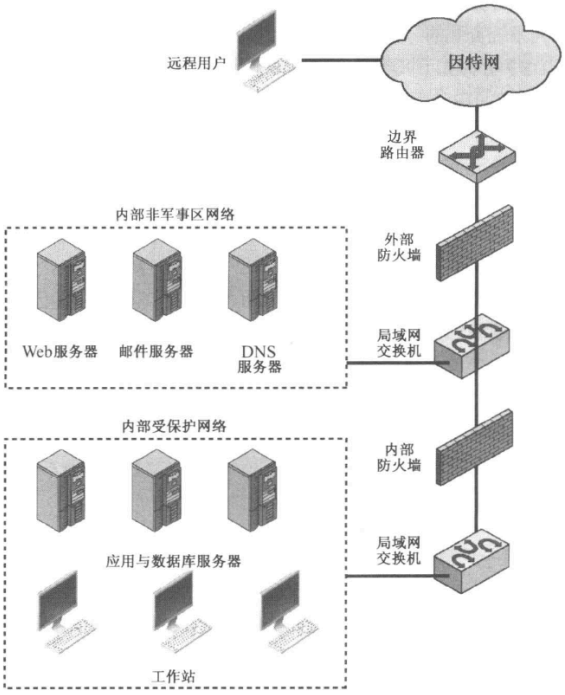


图 21.3　防火墙配置示例

图 21.3 外部防火墙、DMZ 和内部受保护网络的典型配置

外部防火墙位于企业网边缘，提供基本访问控制。外部防火墙与内部防火墙之间形成 DMZ（非军事区），其中放置必须接受外部连接但仍需保护的系统，如 Web、邮件和 DNS 服务器。内部防火墙位于 DMZ 与核心企业网之间，实施更严格的策略。

3.2 分层配置的优点

1. 内部防火墙采用比外部防火墙更严格的过滤规则，重点保护内部服务器和工作站。
2. 内部防火墙对 DMZ 提供双向隔离：既阻止受感染的 DMZ 主机攻击内部网络，也限制内部网络攻击 DMZ。
3. 多个内部防火墙可以进一步分隔服务器、数据库和用户工作站网段，限制内部攻击和横向传播。

这种配置把需要公开的服务与重要内部资源分开。即使 DMZ 主机失陷，攻击者仍须突破内部防火墙才能进入核心网络。

4. 学习目标 4：入侵检测的基本原理和要求

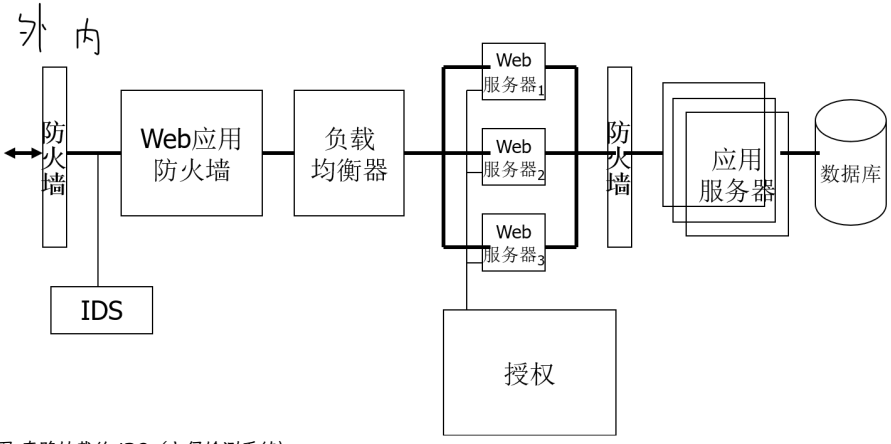


图 旁路挂载的 IDS（入侵检测系统）

4.1 基本概念

- **入侵**：违反安全策略，试图损害系统或网络的保密性、完整性或可用性；攻击者既可能来自外部，也可能是滥用权限的授权用户。
- **入侵检测**：收集并分析系统或网络事件，以发现入侵迹象的过程。
- **入侵检测系统（IDS）**：从计算机或网络的不同区域收集和分析信息，识别未授权资源访问，并提供实时或近实时警告的软硬件系统。

IDS 是认证、访问控制和防火墙之后的另一道防线。它的价值包括尽早发现并驱离攻击者、减少损失和恢复时间、形成威慑，以及收集攻击技术信息来改进后续防护。

4.2 IDS 的三个逻辑组件

组件	职责
传感器	从网络数据包、日志文件、系统调用轨迹等来源采集可能包含入侵证据的数据。
分析器	接收一个或多个传感器或分析器的输入，判断是否发生入侵，输出证据并可给出响应建议。
用户接口	展示检测结果并允许用户控制系统，也可称管理器、控制器或控制台。

4.3 两种检测方法

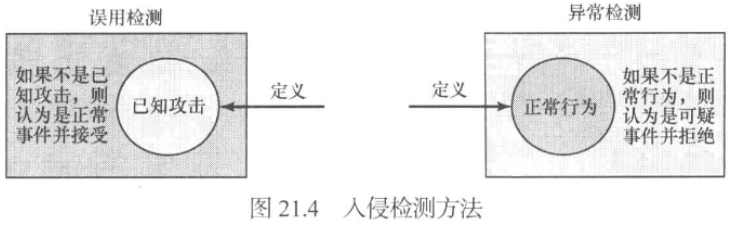


图 21.4　入侵检测方法

图 21.4 入侵检测方法

方法	判定依据	优点	缺点
误用检测	将事件、事件序列或系统性质与已知攻击规则和签名匹配。	对已知攻击准确率较高，误报较少。	无法检测没有签名的新攻击或未知攻击。

方法	判定依据	优点	缺点
异常检测	建立正常行为模型，寻找明显偏离正常模式的活动。	可能依据活动审计发现未知攻击。	正常行为和攻击行为会重叠，必须权衡误报与漏报。

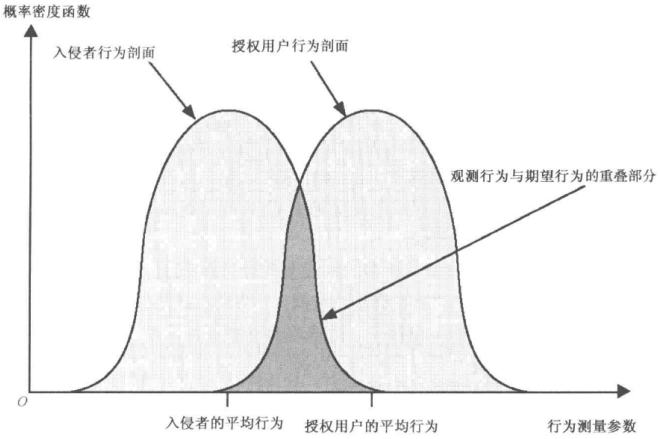


图 21.5　入侵者和授权用户行为剖面图

图 21.5 入侵者与授权用户行为分布的重叠导致误报和漏报折中

检测结论可用下表理解：

实际情况	报告发生	报告未发生
入侵实际发生	判断为真	漏报
入侵实际未发生	误报	判断为假

异常判定范围越宽，通常能发现更多入侵，但误报也会增加；判定范围越严格，误报减少，但漏报会增加。

5. 学习目标 5：入侵检测系统的主要特征

5.1 基于主机的 IDS

基于主机的 IDS（HIDS）在数据库服务器、管理系统等敏感主机上增加专用安全软件层，直接监控主机活动、数据文件和系统进程。它更容易确定发起攻击的进程和用户账号，也能检测基于网络的 IDS 或防火墙不易发现的内部入侵。

HIDS 可结合误用检测和异常检测。常见异常检测策略有：

- **阈值检测**：根据某类事件的发生频率设置与用户无关的阈值；
- **基于配置文件的检测**：为每个用户建立活动配置文件，检测账号行为的变化。

IDS 的主要目的仍是检测、记录和报警；某些系统也可能在损失发生前阻止攻击。

5.2 基于网络的 IDS

基于网络的 IDS（NIDS）把网卡设为混杂模式，捕获并检查其所在网段的流量。单个传感器只能观察本地网段，不能看到其他网段或电话线等其他通信路径，所以实际部署通常使用多个传感器并由中央管理器汇总威胁信息。

NIDS 常用三类签名：

签名	检查对象	教材示例
字符串签名	净荷中的攻击文本串，可组合多个字符串降低误报。	针对 UNIX 或 Web 服务器攻击的特定字符串组合。
端口签名	对经常遭到攻击或本不应开放的端口进行监控。	Telnet 23、FTP 21/20、SUNRPC 111、IMAP 143。
头部签名	数据包头部中危险或逻辑矛盾的标志组合。	同时设置 TCP SYN 和 FIN，或针对 NetBIOS 的异常指针。

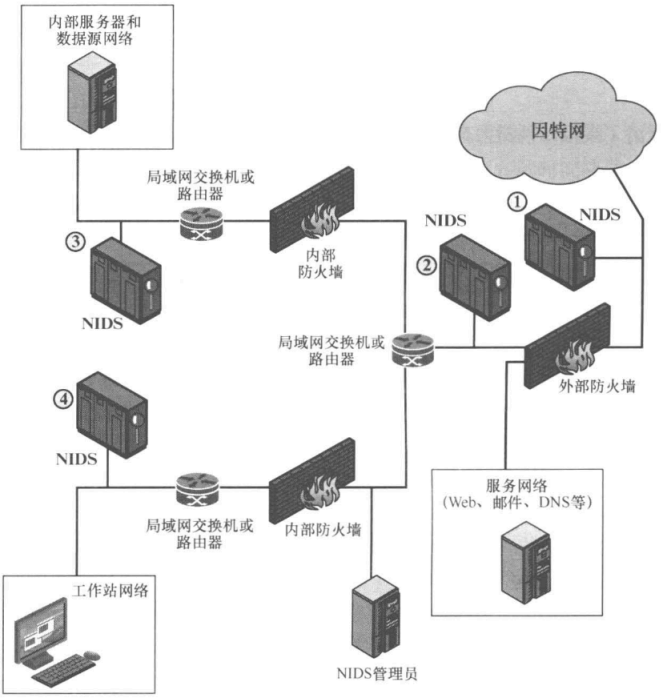


图 21.6　NIDS 传感器部署示例

图 21.6 NIDS 传感器在企业网络关键位置的部署示例

四类典型部署位置及其观察目标是：

1. 主防火墙外：测量来自因特网的总体威胁水平。
2. DMZ 内：监控针对 Web、邮件、DNS 等公开服务的渗透。
3. 内部防火墙后、骨干网络处：监控内部服务器和数据库资源所在网段。
4. 内部防火墙后、用户局域网处：监控特定工作站和服务器网段，并发现来自企业内部的攻击。

HIDS 与 NIDS 的观察范围不同：HIDS 看得见主机内部行为及攻击结果，NIDS 看得见特定网段上的跨主机流量。二者配合才能扩大检测覆盖面。

6. 学习目标 6：主要恶意软件

恶意软件是秘密嵌入或运行于系统中，以破坏数据、执行侵入性程序，或损害数据、应用和操作系统的保密性、完整性、可用性的软件。它既可攻击应用、实用程序和内核，也可能存在于恶意网站、服务器、垃圾邮件及其他诱骗消息中。

类型	核心特征
病毒（Virus）	能自我复制并附着于宿主程序，在用户不知情或未许可时感染系统；可能破坏、删除数据或借邮件传播。
蠕虫（Worm）	独立、自我复制并**利用网络自行传播**，不需人工干预，也不集成到已有代码中；通常攻击已知漏洞。
特洛伊木马（Trojan Horse）	表面具有有用功能，内部隐藏恶意功能，可借调用者的合法授权逃避安全机制。
间谍软件（Spyware）	秘密安装，在个人或企业不知情的情况下收集信息。
Rootkit	攻击者取得根级访问后使用的一组工具，用于隐藏活动并长期维持隐蔽的高权限访问。
后门（Backdoor）	绕过正常安全控制、秘密进入系统的非法途径，常由攻击者或恶意软件安装。
移动代码（Mobile cod…	可不经修改地发布到异构平台并以相同语义运行的脚本、宏或其他可移植指令。
僵尸（Bot）	安装在受控系统上并接受指令发动攻击的程序；大量协同僵尸构成僵尸网络。

病毒与蠕虫的关键区别是：病毒依附宿主程序，蠕虫是独立程序并能通过网络自动传播。

7. 学习目标 7：恶意软件防御的关键要素

7.1 两个时间尺度

- **实时或近实时防御**：监控并阻止正在发生或即将发生的攻击，也可删除恶意软件并报告事件。
- **攻击后防御**：分析事件报告和流量模式，根据经验改进安全控制。

7.2 五个防御要素

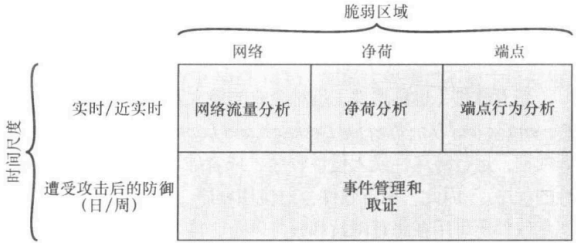


图 21.7　恶意软件防御的五个要素

要素	时间尺度	主要内容
网络流量分析	实时/近实时	在网络边界、内部设备或端点附近监控流量，以签名或异常检测发现流量激增、异常 DNS 活动等迹象。
净荷分析	实时/近实时	检查数据包中的应用数据，寻找已知恶意净荷或异常模式；可在沙箱中隔离并观察可疑净荷。
端点行为分析	实时/近实时	使用杀毒软件、应用白名单和应用容器，识别恶意行为、限制可执行程序并隔离应用和文件。
事件管理	攻击后	完成数据收集、聚合、规范化、关联、警报和报告/合规，更新签名及异常配置文件。
取证	攻击后	在保持数据完整性和严格监管链的前提下识别、收集、检查和分析证据。

事件管理把防火墙、代理服务器、数据库、IDS/IPS、操作系统、路由器、交换机和访问控制系统等不同来源的数据统一起来。其中：

- 聚合用于在关联或保留前整合资源；
- 规范化把不同表示转换为公共格式；
- 关联在一定时间窗口内连接多个事件，发现单个事件无法揭示的异常；
- 警报触发仪表板通知、电子邮件或文本消息等响应；
- 报告用于收集满足组织或政府政策要求的数据。

数字取证重点回答发生了什么、由谁造成、何时发生、如何发生、事件顺序、影响对象与程度以及发生原因。多数事件可通过常规事件管理处理，严重事件才需要深入取证。

8. 学习目标 8：分布式拒绝服务攻击的本质

8.1 DoS 与 DDoS

拒绝服务（DoS）攻击试图阻止合法用户正常使用服务；攻击来自大量分布式受控主机时称为 DDoS。 DDoS 通过海量无用流量或请求淹没服务器、网络或终端系统，使合法用户无法访问资源。

DDoS 所消耗的资源主要分为两类：

目标资源	典型方式	结果
目标系统内部资源	SYN 洪泛、耗尽进程表或磁盘空间。	服务器状态结构或存储资源耗尽，无法处理合法请求。
局域网数据传输能力	大量主机或反射器向目标发送响应流量。	目标路由器或链路带宽被占满，合法流量无法通过。

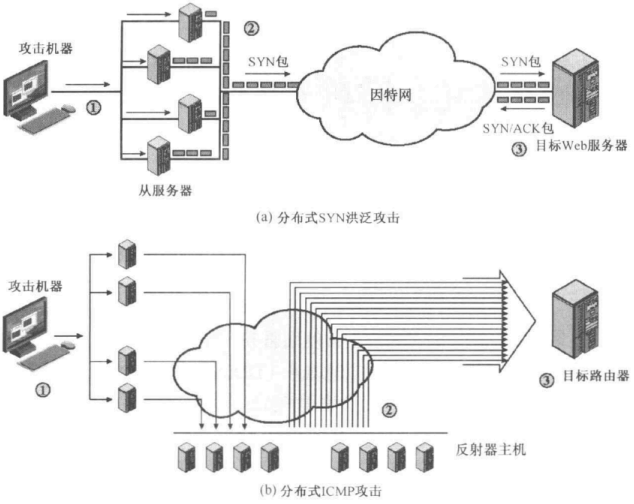


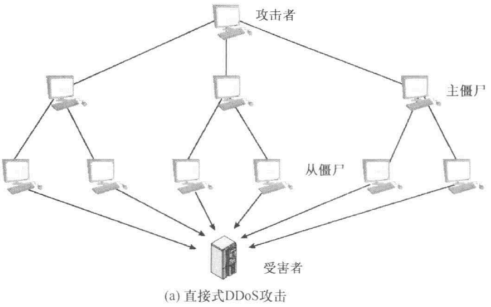
图 21.8　简单 DDoS 攻击的例子

图 21.8 SYN 洪泛与反射式 ICMP 洪泛的资源消耗方式

8.2 SYN 洪泛过程

1. 攻击者控制多台主机，命令它们连接目标服务器。
2. 受控主机发送带有伪造源 IP 地址的 TCP SYN 数据包。
3. 服务器为每个 SYN 返回 SYN/ACK，并为等待回应的"半开"连接保留状态结构。
4. 伪造地址不会完成握手，大量半开连接最终耗尽服务器资源，合法连接因此被拒绝。

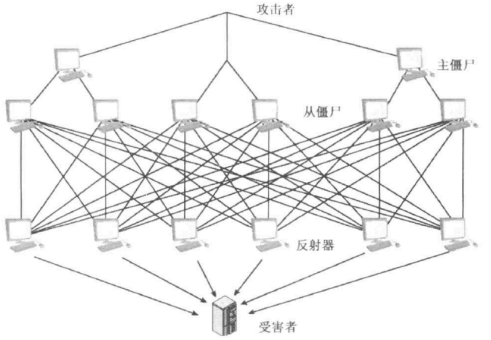
8.3 直接式与反射式 DDoS（另一种分类方式）



(a) 直接式DDoS攻击

图 21.9　基于洪泛的 DDoS 攻击类型

图 21.9(a) 直接式 DDoS：攻击者经主僵尸控制从僵尸攻击受害者



(b) 反射式DDoS攻击

图 21.9　基于洪泛的 DDoS 攻击类型（续）

图 21.9(b) 反射式 DDoS：从僵尸伪造受害者地址，诱使反射器向受害者响应

类型	攻击路径	特点
直接式 DDoS	攻击者 → 主僵尸 → 从僵尸 → 受害者。	两层僵尸结构使攻击源更难追踪，并提高控制灵活性。
反射式 DDoS	攻击者 → 主/从僵尸 → 未感染反射器 → 受害者。	从僵尸把受害者 IP 伪装成源地址；反射器的响应汇聚到受害者，涉及主机更多、流量更大，也更难过滤和追踪。

8.4 构建攻击网络

建立 DDoS 攻击网络需要三个基本要素：能隐藏、接受指令并实施攻击的僵尸软件；大量具有普遍漏洞且未及时修补的系统；发现这些脆弱主机的扫描策略。

扫描策略	方法
随机扫描	各感染主机使用不同种子随机探测 IP 地址空间，流量很大。
攻击列表扫描	攻击者预先制作脆弱主机列表，再让感染主机各自扫描其中一部分，感染速度快且较难察觉。
局部解剖扫描	利用已感染主机自身掌握的信息寻找更多目标。
局域子网扫描	已进入防火墙内部的感染主机利用本地地址结构搜索同一局域网中的其他目标。

8.5 三道 DDoS 防线

1. **攻击预防和抢占（攻击前）**：实施资源消耗策略、准备按需后备资源，并改进系统和网络协议，以提高承受攻击的能力并降低受攻击概率。
2. **攻击检测和过滤（攻击中）**：尽早识别可疑行为模式并过滤攻击数据包，以降低攻击影响。
3. **攻击源追踪和识别（攻击中和攻击后）**：尝试确定攻击来源，为缓解当前攻击和预防后续攻击提供依据。

DDoS 的困难在于攻击方式多样且不断变化，因此没有单一机制能够彻底解决问题，三道防线需要持续更新并协同工作。

本章关键术语整理

术语	核心含义
防火墙	在网络边界或内部网段之间执行访问控制、监控和审计的安全系统。
数据包过滤防火墙	根据单个数据包的网络层和传输层字段实施规则的防火墙。
状态检查防火墙	维护连接状态，并结合状态与数据包字段实施过滤的防火墙。
应用层网关	终止并代理应用连接、能够检查和限制应用功能的防火墙。
电路层网关	建立两个 TCP 连接并在获准后中继数据的代理。
DMZ	位于外部与内部防火墙之间、用于部署对外服务的隔离网络。
IDS	收集和分析主机或网络事件、发现未授权访问并告警的系统。
误用检测	通过已知攻击规则或签名识别入侵的方法。
异常检测	通过偏离正常行为模型的活动识别入侵的方法。
HIDS	监视单台主机内部活动、进程、账号和文件的入侵检测系统。
NIDS	捕获并分析特定网段流量的入侵检测系统。
恶意软件	以破坏数据或损害系统保密性、完整性、可用性为目的的软件。
僵尸网络	由攻击者协同控制的大量感染主机组成的攻击网络。
事件管理	对安全事件进行侦测、报告、评估、响应、处理和经验总结的过程。
数字取证	在保持证据完整性和监管链的前提下识别、收集、检查和分析数据。
DoS	试图阻止合法用户正常使用服务的攻击。
DDoS	利用大量分布式受控主机共同耗尽目标资源的拒绝服务攻击。
反射器	接收伪造源地址的请求并把响应发送给受害者的未感染主机。

学习目标自检

1. 能否说明防火墙在深度防御中的位置、三个设计目标、四项主要作用及能力边界？
2. 能否列出防火墙的四种访问控制功能，并比较四类防火墙的工作方式、优点和局限？
3. 能否解释外部防火墙、DMZ 和内部防火墙的相对位置及分层配置的三项优点？
4. 能否定义入侵、入侵检测和 IDS，说明 IDS 的三个逻辑组件，并比较误用检测与异常检测？
5. 能否比较 HIDS 与 NIDS 的数据来源和检测能力，列出 NIDS 的三类签名及四类部署位置？
6. 能否区分病毒、蠕虫、特洛伊木马、间谍软件、Rootkit、后门、移动代码和僵尸？
7. 能否从两个时间尺度说明恶意软件防御，并概述网络流量分析、净荷分析、端点行为分析、事件管理和取证？
8. 能否说明 DDoS 消耗的两类资源、SYN 洪泛过程、直接式与反射式攻击、僵尸网络构建及三道防线？